

HOW TO BECOME A SOC ANALYST

A practical beginner guide to security operations, SIEM, alert triage, threat hunting, incident response, and career preparation

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Purpose and ethical-use notice

This manual provides a practical path into security operations. Use all tools, logs, packet captures, malware samples, and investigative techniques only in systems you own, approved laboratories, or environments for which you have explicit authorization.

***Technical ability does not create permission.** Protect privacy, preserve evidence, follow scope, and escalate when an investigation may affect people, legal obligations, or business operations.*

Table of contents

- 1. What a SOC analyst does
- 2. SOC roles and career progression
- 3. Foundational knowledge
- 4. Logs and telemetry
- 5. SIEM platforms
- 6. Alert triage workflow
- 7. Endpoint investigations
- 8. Identity investigations
- 9. Network investigations
- 10. Email and phishing investigations
- 11. Cloud investigations
- 12. MITRE ATT&CK and threat intelligence
- 13. Detection engineering
- 14. Threat hunting
- 15. Incident response
- 16. Case management and reporting
- 17. Home lab and safe practice
- 18. Portfolio projects
- 19. Resume and interview preparation
- 20. 30/60/90-day plan
- 21. Accessibility and sustainable learning
- 22. Checklists and templates
- 23. Glossary
- 24. Official learning resources

1. What a SOC analyst does

A Security Operations Center (SOC) analyst monitors security data, investigates suspicious activity, documents findings, and helps coordinate response. The analyst turns large volumes of technical signals into clear decisions: close as benign, continue investigating, contain, or escalate.

Responsibility	Practical example
Monitor	Review SIEM queues, endpoint alerts, identity-risk events, and cloud findings.
Triage	Determine whether an alert is a true positive, false positive, expected activity, or unresolved.
Investigate	Build a timeline using users, hosts, IP addresses, processes, files, and authentication events.
Respond	Contain according to authority, or provide clear recommendations to the incident team.
Document	Record evidence, reasoning, business impact, actions, and follow-up tasks.
Improve	Tune noisy rules, identify telemetry gaps, and propose new detections.

2. SOC roles and career progression

Level	Typical focus	Evidence of readiness
Tier 1 / Junior	Queue monitoring, enrichment, basic triage, phishing review	Consistent notes, correct escalation, basic queries, sound judgment
Tier 2 / Analyst	Deeper endpoint, identity, network, and cloud investigation	Timelines, scoping, threat hunting, detection feedback
Tier 3 / Senior	Advanced investigations, threat hunting, detection engineering	Complex cases, mentoring, cross-platform analysis
Lead / Manager	Operations, metrics, staffing, quality, stakeholder communication	Program improvement, governance, executive reporting
Detection Engineer / Hunter	Analytics, rule development, hypotheses, validation	Versioned detections, test cases, coverage mapping

3. Foundational knowledge

- Networking: TCP/IP, DNS, HTTP/S, ports, NAT, VPNs, proxies, firewalls, and common protocols.
- Windows: processes, services, registry, event logs, PowerShell, scheduled tasks, and authentication.

- Linux: processes, permissions, services, logs, shell history, SSH, cron, and package management.
- Identity: users, groups, MFA, SSO, tokens, conditional access, privileged access, and service accounts.
- Cloud: accounts/subscriptions, IAM, audit logs, storage, compute, networking, and shared responsibility.
- Security fundamentals: malware, phishing, credential theft, lateral movement, persistence, exfiltration, and ransomware.
- Professional skills: concise writing, curiosity, calm escalation, evidence preservation, and respect for privacy.

4. Logs and telemetry

Source	What it can answer
Endpoint / EDR	Which process ran? What file changed? What network connection was made?
Windows event logs	Who logged in? Which service, task, group, or policy changed?
Identity provider	Was MFA used? Was the sign-in risky, unusual, or from a new device?
DNS	Which domains were queried, by which host, and when?
Firewall / proxy	Which connections were allowed or blocked? How much data moved?
Email security	Who sent the message? What URLs, attachments, and authentication results were present?
Cloud audit	Who changed a resource, role, policy, key, or network rule?
Application logs	What action occurred inside the business application?

Good analysis depends on time synchronization, stable host and user identifiers, useful retention, normalized fields, and an understanding of missing data. Absence of a log is not proof that an event did not occur.

5. SIEM platforms

A SIEM collects, normalizes, searches, correlates, and presents security data. Common platforms include Microsoft Sentinel, Splunk Enterprise Security, Elastic Security, Wazuh, and Security Onion. Learn concepts first: data ingestion, schemas, queries, detections, alert queues, cases, enrichment, automation, and retention.

Platform	Beginner focus
----------	----------------

Microsoft Sentinel	KQL queries, analytics rules, incidents, entities, workbooks, automation.
Splunk	SPL searches, fields, data models, notable events, dashboards.
Elastic Security	KQL/Lucene, alerts, timelines, cases, endpoint and cloud data.
Wazuh	Agent events, file integrity, vulnerability findings, rules, dashboard.
Security Onion	Network security monitoring, Zeek, Suricata, packet analysis, cases.

6. Alert triage workflow

1. Read the alert title, rule logic, time range, severity, and source.
2. Confirm the affected user, host, IP address, application, and data classification.
3. Validate that the telemetry is complete and timestamps use the correct time zone.
4. Enrich with asset criticality, user role, reputation, threat intelligence, and recent changes.
5. Build a timeline before forming a conclusion.
6. Compare behavior with a known baseline and approved activity.
7. Decide: false positive, benign true positive, suspicious, confirmed incident, or insufficient evidence.
8. Contain or escalate according to authority and playbook.
9. Document facts, reasoning, actions, and remaining uncertainty.
10. Provide detection-tuning or telemetry-gap feedback.

Triage questions

- What exactly triggered the alert?
- What evidence supports malicious intent?
- Could this be legitimate administration, automation, testing, or travel?
- What happened immediately before and after?
- Is the activity isolated or present on other users or hosts?
- What is the potential business impact?
- What action is authorized right now?

7. Endpoint investigations

- Identify process tree, command line, parent-child relationships, user context, hashes, signatures, persistence, and network connections.
- Check whether the executable is expected for that host and user.
- Review recent downloads, browser history, email attachments, removable media, and software installations when authorized.

- Look for scheduled tasks, services, startup entries, registry run keys, WMI persistence, and unusual PowerShell.
- Avoid deleting evidence before preservation and coordination.

8. Identity investigations

- Review successful and failed sign-ins, MFA events, device, location, IP, user agent, token use, and risk detections.
- Compare with the user's normal pattern and approved travel or VPN use.
- Check password resets, group changes, new credentials, mailbox rules, OAuth grants, role assignments, and service-account activity.
- Treat impossible travel as a lead, not automatic proof; VPNs, mobile networks, and cloud services can distort location.
- Contain by revoking sessions, resetting credentials, disabling accounts, or removing grants only when authorized.

9. Network investigations

- Start with source, destination, protocol, port, direction, bytes, duration, and allow/block action.
- Use DNS, proxy, firewall, VPN, Zeek, Suricata, and packet data together when available.
- Look for unusual beaconing, rare destinations, new domains, unexpected protocols, lateral movement, and large outbound transfers.
- Do not label traffic malicious solely because a port is uncommon. Validate the application and context.
- Packet captures may contain credentials and personal data; restrict access and retention.

10. Email and phishing investigations

- Preserve the original message and headers.
- Review sender domain, reply-to, return-path, SPF, DKIM, DMARC, URLs, attachments, display-name deception, and message routing.
- Use a safe analysis environment; never open suspicious attachments on a production workstation.
- Search for other recipients and related messages.
- Determine whether anyone clicked, entered credentials, executed a file, or approved MFA.
- Block indicators and remove messages only within authorized procedures.
- Communicate clearly with the user without blame.

11. Cloud investigations

- Identify the cloud account, tenant, subscription/project, resource, identity, action, source IP, user agent, and time.

- Review IAM changes, new keys, public exposure, network-rule changes, storage access, unusual compute creation, and audit-log changes.
- Distinguish management-plane actions from data access.
- Check infrastructure-as-code and approved deployment pipelines before assuming a human made the change.
- Preserve cloud audit evidence and record resource identifiers.

12. MITRE ATT&CK and threat intelligence

MITRE ATT&CK provides a common language for adversary tactics and techniques. Use it to describe observed behavior and identify detection gaps, not to force every alert into a technique. Threat intelligence adds context, but an indicator match is a lead rather than final proof.

- Record source, confidence, first/last seen, scope, and expiration for indicators.
- Prefer behavior and multiple corroborating signals over a single reputation score.
- Map detections to ATT&CK techniques and review coverage honestly.
- Remove or expire stale indicators to reduce noise.

13. Detection engineering

11. Define the threat behavior and required telemetry.
12. Write a clear analytic hypothesis.
13. Create the query or rule and document field assumptions.
14. Test with known-good and safe simulated data.
15. Measure false positives, blind spots, latency, and cost.
16. Add severity, entities, enrichment, response guidance, and ATT&CK mapping.
17. Version the detection and retain test evidence.
18. Tune carefully; do not suppress an alert merely because it is inconvenient.

Detection quality question	Example
Specificity	Does the rule identify behavior rather than a common tool name alone?
Context	Does it consider user role, asset criticality, and expected administration?
Testability	Can a safe test reproduce the intended signal?
Actionability	Can an analyst understand what to investigate next?
Maintainability	Are owner, version, data source, and review date documented?

14. Threat hunting

Threat hunting is a structured search for activity not already identified by alerts. Begin with a hypothesis grounded in threat behavior, business context, intelligence, or a control gap.

- State the hypothesis and expected evidence.
- Identify data sources and limitations.
- Run broad searches, then narrow by time, entity, rarity, and sequence.
- Validate findings with additional telemetry.
- Document negative findings and blind spots.
- Convert repeatable findings into detections or controls.

15. Incident response

Phase	SOC contribution
Preparation	Playbooks, contacts, tools, access, logging, exercises.
Detection and analysis	Validate, scope, classify, preserve evidence, notify.
Containment	Recommend or execute approved isolation, blocking, session revocation.
Eradication and recovery	Support removal, restoration, validation, and heightened monitoring.
Lessons learned	Timeline, root cause, control gaps, metrics, and assigned actions.

***Do not exceed your authority.** A junior analyst who escalates quickly with strong evidence is performing correctly.*

16. Case management and reporting

- Use a precise title with affected entity and behavior.
- Write timestamps with time zone.
- Separate facts, assumptions, and conclusions.
- Record every query, evidence source, action, and communication.
- Explain business impact in plain language.
- State what remains unknown.
- Protect personal and confidential data.
- Use neutral language and avoid blaming users.

Sample case summary

At 14:22 UTC, the identity platform recorded a successful sign-in for user jdoe from an IP address not previously associated with the account. MFA was approved. Five minutes later, a new mailbox forwarding rule was created. The user confirmed they did not perform either action. The account

was disabled and sessions were revoked under the identity-compromise playbook. The case was escalated for mailbox review and notification assessment.

17. Home lab and safe practice

- Use an isolated virtual lab with no route to production systems.
- Use synthetic users and data. Never import employer or customer logs without permission.
- Take snapshots before testing.
- Use intentionally vulnerable systems and authorized training platforms.
- Do not expose lab services directly to the internet.
- Keep malware samples out of beginner labs unless supervised and properly isolated.
- Document scope, safety controls, and cleanup.

Suggested lab

- One Windows virtual machine generating event logs.
- One Linux virtual machine.
- Wazuh or Elastic in an isolated lab, or a controlled Sentinel learning environment.
- Sysmon on Windows where appropriate.
- A small collection of safe simulated events.
- A GitHub repository containing sanitized queries, screenshots, case notes, and lessons learned.

18. Portfolio projects

Project	Deliverables
Phishing investigation	Sanitized headers, timeline, indicators, conclusion, response recommendations.
Windows log investigation	Event IDs, process timeline, queries, ATT&CK mapping, limitations.
SIEM detection	Rule, test data, expected result, false-positive analysis, tuning notes.
Threat hunt	Hypothesis, data sources, queries, findings, gaps, proposed detection.
Incident report	Executive summary, technical timeline, impact, containment, lessons learned.
SOC dashboard	Purpose, data sources, metrics, screenshots, privacy considerations.

Never publish real credentials, customer data, internal IP addresses, private indicators, proprietary rules, or unredacted production screenshots.

19. Resume and interview preparation

- Describe investigations with action, evidence, and outcome.

- List platforms honestly and distinguish lab experience from production experience.
- Show queries, reports, and detections in a sanitized portfolio.
- Prepare to explain one alert from initial signal through final disposition.
- Practice communicating uncertainty and escalation decisions.
- Do not claim certifications, tools, or incident experience you do not have.

Example resume bullets

- Investigated simulated endpoint and identity alerts in a controlled lab, built timelines from multiple log sources, and documented escalation decisions.
- Created and tested SIEM analytics mapped to MITRE ATT&CK, including false-positive analysis and tuning notes.
- Produced sanitized phishing and incident reports demonstrating evidence handling, business-impact communication, and remediation recommendations.

Common interview questions

- Walk me through your alert-triage process.
- How do you distinguish a false positive from a benign true positive?
- What logs would you use for suspected account compromise?
- How would you investigate a suspicious PowerShell alert?
- When would you escalate an incident?
- How do you handle missing telemetry?
- Describe a detection you built or improved.
- How do you protect privacy during an investigation?

20. 30/60/90-day learning plan

Days 1-30: foundations

- Study networking, Windows, Linux, identity, and common attacks.
- Learn basic query syntax in one SIEM.
- Complete simple log and phishing investigations.
- Create a glossary and investigation notebook.
- Publish one sanitized case report.

Days 31-60: investigation

- Practice endpoint, identity, network, and cloud timelines.
- Map observations to ATT&CK.
- Build two basic detections with test evidence.
- Complete one threat-hunting exercise.
- Practice concise escalation messages.

Days 61-90: job readiness

- Complete three portfolio projects.

- Review ten job descriptions and identify recurring skills.
- Tailor the resume without exaggeration.
- Practice technical and behavioral interviews.
- Apply to SOC, security monitoring, incident-response, and junior detection roles that match location and work authorization.

21. Accessibility and sustainable learning

- Use text transcripts, captions, keyboard-accessible labs, screen-reader-friendly documents, and adjustable text size.
- Break investigations into repeatable checklists.
- Use templates to reduce working-memory load.
- Request reasonable accommodations for interviews, training, and work.
- Schedule breaks during long alert queues and emotionally difficult investigations.
- A good analyst is measured by judgment, evidence, and communication - not by typing speed or memorizing every command.

22. Checklists and templates

Alert triage checklist

- Alert logic understood
- Time zone confirmed
- Entities identified
- Asset and user context added
- Telemetry completeness checked
- Timeline built
- Related alerts searched
- Hypotheses tested
- Disposition selected
- Actions and evidence documented
- Escalation or closure approved
- Detection feedback recorded

Investigation note template

Field	Content
Case ID	
Alert / hypothesis	
Date and analyst	
Affected users and assets	
Known facts	
Timeline	
Queries and evidence	

Assessment and confidence	
Actions taken	
Remaining questions	
Escalation / closure	

23. Glossary

Term	Definition
Alert	A signal generated by a rule, analytic, product, or control that requires review.
Case / incident	A managed record combining evidence, analysis, decisions, and response.
EDR	Endpoint Detection and Response.
False positive	An alert that incorrectly indicates the targeted behavior.
Benign true positive	The rule correctly observed the behavior, but the activity was authorized or harmless.
IOC	Indicator of Compromise, such as a hash, domain, IP, or artifact.
SIEM	Security Information and Event Management.
SOAR	Security Orchestration, Automation, and Response.
Triage	Initial validation, enrichment, prioritization, and disposition.
Threat hunting	Hypothesis-driven search for undetected malicious behavior.

24. Official learning resources

[Microsoft Sentinel](#)

[MITRE ATT&CK](#)

[CISA Incident Response](#)

[Elastic Security](#)

[Wazuh Quickstart](#)

[Splunk Enterprise Security](#)

[Sigma](#)

[YARA](#)

[Wireshark](#)

[Security Onion](#)

[CyberDefenders](#)

[LetsDefend](#)

[Blue Team Labs Online](#)

[Microsoft Learn Sentinel training](#)

Verify availability, pricing, regional access, and current product behavior before relying on any external platform. Product interfaces and licensing can change.

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0).